

From Risk Narratives to Trust Requirements: Bridging AI Governance with Requirements Engineering

Sahaj Vaidya

AI Research and Development Lead

CKC Cares

Email: sahajs235@gmail.com

Abstract—AI governance frameworks such as the EU AI Act and ISO/IEC 42001 define high-level risk categories and ethical principles for trustworthy AI but fall short of providing concrete mechanisms to operationalize these principles during system design. This gap creates significant challenges for AI developers and organizations seeking to translate broad governance goals—such as mitigating systemic bias or enhancing explainability—into actionable, verifiable system requirements during the requirements engineering (RE) phase. In this paper, we propose a novel framework that systematically transforms *risk narratives*—contextualized descriptions of potential harms and ethical concerns—into *trust requirements* that are elicitable, traceable, and testable within standard RE workflows. Our approach integrates policy modeling with established RE traceability practices to ensure alignment between governance mandates and technical specifications. We further illustrate a tangible methodology supported by a conceptual tool mock-up that enables organizations to bridge the policy-to-product gap early in the AI lifecycle. This integration promises to improve the accountability, transparency, and robustness of AI systems by embedding governance goals directly into design-time requirements.

Index Terms—AI Governance, Requirements Engineering, Trust Requirements, Risk Narratives, EU AI Act, ISO/IEC 42001, AI Ethics, Traceability, Explainability, System Design.

I. INTRODUCTION

AI systems are increasingly deployed in high-risk sectors such as healthcare, finance, and public services, prompting a global push for governance mechanisms that ensure accountability, fairness, and transparency [1], [2]. Regulatory frameworks such as the European Union’s AI Act [1], ISO/IEC 42001 [3], and the NIST AI Risk Management Framework [2] aim to guide organizations in the responsible development and deployment of AI. These frameworks categorize AI systems by risk and articulate high-level governance goals. However, they often stop short of prescribing specific, actionable requirements that can be incorporated into technical workflows, especially at the design stage.

This creates a significant and underexplored challenge: How can AI governance principles be operationalized during requirements engineering (RE), the phase in software development where system requirements are defined, negotiated, and validated? Current practices often treat governance compliance as a post-hoc or audit activity, missing the opportunity to integrate trust principles directly into the development lifecycle

[4], [5]. The result is a persistent gap between governance policies and the practical realities of AI system design and implementation.

A. Contributions

In this paper, we propose a conceptual framework and methodology that aim to bridge this critical gap by converting *risk narratives*—contextual descriptions of AI-related harms such as systemic bias, lack of explainability, and safety concerns—into verifiable *trust requirements*. These trust requirements can be elicited, validated, and traced through the RE process. Our contributions include:

- A structured methodology for translating policy-aligned risk narratives into trust requirements that align with system-level objectives and are traceable throughout development.
- A synthesis of policy modeling techniques and RE traceability practices to support the formal linkage between governance mandates and system specifications.
- A conceptual tool mock-up illustrating how organizations can support early-stage integration of governance goals into product development cycles.

By anchoring governance compliance at design time, our approach enables organizations to embed accountability and transparency into the architecture of AI systems, thereby facilitating continuous assurance and regulatory alignment.

II. LITERATURE REVIEW

A. AI Governance and Risk Categorization

The EU AI Act [1] and ISO/IEC 42001 [3] form foundational governance instruments that classify AI systems by risk tier and offer management principles for risk mitigation. However, they fall short in detailing how to convert these principles into executable system requirements. As Binns [6] and Wachter et al. [?] argue, governance efforts often prioritize abstract ethical declarations over actionable technical criteria. The NIST AI Risk Management Framework [2] attempts to bridge this gap by outlining outcomes for responsible AI, but even it lacks guidance on transforming these outcomes into system-level specifications.

Fjeld et al. [7] analyzed over 30 AI ethics guidelines and noted a convergence on values like fairness and accountability,

but a divergence in implementation pathways. This lack of standardization creates ambiguity for practitioners seeking compliance. Jobin et al. [?] similarly highlight the absence of concrete implementation mechanisms in AI ethics declarations, which limits their utility in RE processes.

B. Requirements Engineering for Trustworthy AI

The literature in RE has begun acknowledging the importance of incorporating ethical considerations into system requirements. Traditional RE processes focus on functional and non-functional requirements [8], but researchers such as Vakkuri et al. [5] have advocated for integrating ethical dimensions such as transparency and autonomy into early system design. Still, there remains a methodological void in linking governance goals to RE outputs.

Martin et al. [4] emphasize that RE professionals often lack the tools and training to translate policy concerns into elicitable requirements. Breaux et al. [9] demonstrated early attempts at translating legal policies into system specifications, yet these methods were tailored for data privacy and not adaptable to dynamic AI risks such as drift or emergent behavior.

Recent proposals like the RE4AI framework [?] offer templates for ethics-based requirement elicitation, but these remain under-tested in real-world contexts. The interplay between data characteristics and ethical risks further complicates requirement specification, requiring a multi-layered modeling approach that accounts for data provenance, model behavior, and stakeholder values.

C. Traceability and Policy Modeling

Traceability—the ability to trace a requirement from its origin to implementation and verification—is vital for compliance in regulated domains [10]. For AI, traceability must span not only code and documentation but also data lineage, model decisions, and policy mandates [11]. Without such multi-level traceability, organizations struggle to demonstrate conformance with governance standards.

Breaux and Antón [?] explored the use of goal models and legal ontologies to capture regulatory intent in system design. Their work underscores the feasibility of formalizing governance requirements but has not been widely adopted in the AI domain. The emerging field of algorithmic accountability proposes impact assessments as a bridge between social risks and system design [12], yet these too are largely post-deployment interventions.

Schiff et al. [13] argue for “ethical assurance cases” that integrate normative principles into system-level arguments. However, these remain conceptual and lack supporting tools for RE integration. Our work builds on these insights to propose a unified model that captures both governance and design constraints in a traceable manner.

D. Summary and Gap

In sum, the literature demonstrates a clear consensus on the need to align AI governance with system design. Yet, the

majority of proposed approaches either focus on ethics without traceability or traceability without ethical grounding. There is a notable lack of practical frameworks that translate governance-derived risk narratives into testable, elicitable requirements. Our contribution lies in addressing this methodological lacuna by proposing a structured, tool-supported process that bridges AI governance with RE, thus enabling early lifecycle compliance, enhanced transparency, and sustained trustworthiness.

III. METHODOLOGY

The methodology proposed in this study is aimed at operationalizing high-level AI governance risk narratives—such as opacity, systemic bias, and lack of robustness—into elicitable, verifiable, and traceable requirements at the early stages of AI system development. Our framework builds upon existing practices in requirements engineering (RE), policy modeling, and risk-driven design to enable a structured bridge between AI regulatory mandates and actionable technical specifications. This section outlines the conceptual foundations, methodological components, and procedural steps of the framework.

A. Conceptual Foundations

We draw upon three key strands of literature to ground the methodology:

- 1) **Risk-Driven Requirements Engineering:** Risk-driven RE emphasizes the identification of threats, vulnerabilities, and failure modes as the basis for deriving system requirements [14]. This is compatible with AI governance regimes, where the notion of “unacceptable risk” or “high-risk” systems drives regulatory scrutiny [15].
- 2) **Goal-Oriented Requirements Engineering (GORE):** GORE frameworks like KAOS and i* model stakeholder goals and obstacles to help derive functional and non-functional requirements [16]. GORE supports the translation of policy objectives (e.g., fairness, transparency) into system-level goals.
- 3) **Policy Modeling and Normative Systems:** Techniques from regulatory informatics and policy modeling help represent legal norms in formalized ways, such as through LegalRuleML or compliance ontologies [17]. These provide a structured way to codify risk narratives for integration with technical artifacts.

B. Framework Overview

The framework consists of five sequential and iterative stages:

- 1) Risk Narrative Formalization
- 2) Goal Structuring and Decomposition
- 3) Requirements Elicitation and Specification
- 4) Traceability and Verification Planning
- 5) Governance-to-Design Alignment Assessment

C. 1. Risk Narrative Formalization

Governance documents such as the EU AI Act and ISO/IEC 42001 are analyzed to extract explicit and implicit risk narratives. These narratives are often qualitative and include notions such as "opacity leading to lack of accountability" or "systemic bias leading to unjust outcomes". Using thematic coding and ontological mapping [18], these narratives are formalized into structured policy goals.

Each risk narrative is broken down into:

- **Governance Goal (GG):** High-level policy intent (e.g., Promote algorithmic transparency)
- **Undesirable Outcome (UO):** What the regulation aims to prevent (e.g., Black-box decision-making)
- **Contextual Dependency (CD):** Specific domain or system class where the risk manifests (e.g., Hiring algorithms)

D. 2. Goal Structuring and Decomposition

Using the GORE approach, governance goals are decomposed into sub-goals that reflect stakeholder perspectives. We adapt the goal modeling method proposed by Van Lamsweerde [16] and integrate it with normative system modeling techniques [19].

An example goal tree for fairness might look like:

- GG: Ensure fairness in loan approval AI systems
 - SG1: Avoid disparate impact based on protected attributes
 - SG2: Implement counterfactual fairness tests
 - SG3: Log and audit model decisions for bias

These sub-goals form the basis for technical requirement derivation.

E. 3. Requirements Elicitation and Specification

Each sub-goal is translated into concrete functional and non-functional requirements using structured templates like the Volere schema or IEEE 830 standards [20]. For instance:

- **FR1:** The system shall allow audit logs to be exported in XAI-compliant formats.
- **NFR1:** The fairness metric (e.g., equal opportunity difference) must not exceed 5% deviation across protected groups.

We also integrate legal compliance checks using tools like LKIF or SHACL to validate that requirement expressions conform to governance expectations [21].

F. 4. Traceability and Verification Planning

Traceability is ensured through a traceability matrix linking each governance goal to sub-goals, then to system requirements, test cases, and verification methods [22]. This allows regulators or internal auditors to verify whether and how policy objectives were operationalized.

Verification methods include:

- Simulation tests (for robustness)
- Dataset audits (for bias)
- Explanation plausibility tests (for transparency)

These are mapped onto the verification requirements outlined in NIST AI RMF [23] and ISO/IEC 42001 guidance [3].

G. 5. Governance-to-Design Alignment Assessment

A novel contribution of this framework is an alignment scorecard. Each governance goal is rated on:

- **Coverage:** Are all aspects of the governance goal represented in requirements?
- **Verifiability:** Can derived requirements be empirically verified?
- **Traceability:** Is the link between policy and implementation clearly documented?

A weighted scoring model is used to prioritize areas needing further attention. The model is piloted using hypothetical case studies in domains such as healthcare triage and credit lending AI systems.

H. Tool-Supported Implementation

We provide a low-fidelity prototype (mock-up) tool that visually guides users through the methodology. The tool includes:

- A library of governance goals
- A goal decomposition assistant
- Requirement generation templates
- A traceability dashboard

While the implementation remains conceptual at this stage, it offers a tangible starting point for researchers and organizations to operationalize governance goals.

I. Conclusion of Methodology

This methodology addresses the "governance-to-design gap" by translating abstract AI regulatory expectations into concrete, system-verifiable requirements using a synthesis of RE and normative modeling techniques. The next section evaluates the framework using example risk scenarios and discusses its practical applicability.

IV. INTEGRATING METHODOLOGY WITH CORE CONTRIBUTIONS

This section systematically demonstrates how the proposed methodology operationalizes each of the paper's three primary contributions. Grounded in a transdisciplinary approach that bridges AI governance and requirements engineering (RE), we map policy-derived risk narratives into verifiable, design-time requirements that are both aligned with socio-technical system goals and traceable through development stages.

A. Translating Risk Narratives into Trust Requirements

The first contribution involves the development of a structured methodology that translates high-level risk narratives—such as opacity, bias, or accountability—into design-phase *trust requirements*. Risk narratives are typically articulated within regulatory instruments like the EU AI Act (e.g., Title III for high-risk AI systems) and standards like ISO/IEC 42001. However, these documents primarily define governance

obligations in legal or management language, making them insufficiently actionable for software engineering teams.

To operationalize these narratives, we propose a four-step transformation pipeline:

- 1) **Risk Narrative Extraction:** Using a policy analysis lens informed by computational governance methods [24], we extract salient risks such as “systemic discrimination,” “lack of contestability,” or “non-explainability” from regulatory texts and public trust audits (e.g., Algorithmic Impact Assessments).
- 2) **Decomposition into Trust Constructs:** Each narrative is decomposed into domain-agnostic *trust constructs* based on a modified version of the Trustworthiness Attributes Framework [25], encompassing factors like interpretability, fairness, and robustness.
- 3) **Contextual Mapping:** Using scenario-specific threat modeling and value-sensitive design tools, these constructs are contextually grounded in use-case specifics (e.g., a credit scoring system or predictive policing tool), allowing translation into *system-level concerns*.
- 4) **Requirement Elicitation:** With the guidance of RE best practices like KAOS [26] and Goal-Oriented Requirements Language (GRL), we elicit trust requirements from these concerns, such as: “The system shall generate counterfactual explanations for adverse credit decisions with a confidence threshold of 85%.”

This structured process not only anchors policy narratives in RE methodologies, but also ensures they are articulated in testable, implementable, and traceable forms. Trust requirements thus become engineering proxies for regulatory alignment.

B. Linking Governance Mandates with System Specifications

The second contribution addresses the long-standing disconnect between governance mandates and system-level design decisions. This gap is often exacerbated by the separation between compliance and engineering teams. Our work synthesizes *policy modeling techniques* and *RE traceability practices* to establish a formalized linkage between governance imperatives and system specifications.

We introduce a dual-model framework:

- **Governance Layer (GL):** Encodes policy and regulatory norms as structured objectives and constraints. We adopt elements from Institutional Grammar (IG) [27] and LegalRuleML [28] to represent norms in machine-interpretable forms. For example, a rule such as “AI systems in employment must be subject to bias mitigation” is parsed into deontic logic components.
- **Specification Layer (SL):** Encodes system design decisions, technical requirements, and architectural constraints using SysML or UML artifacts, complemented by trust requirement models.

Between these layers, we implement a bidirectional mapping protocol inspired by traceability matrices and goal refinement structures in RE [29]. Governance goals are linked to

design features through *intermediate trust concerns*, allowing system developers to answer questions such as: “Which system component satisfies the requirement for auditability mandated under Article 13 of the EU AI Act?”

To maintain this alignment across the development lifecycle, we propose a continuous mapping mechanism. Changes in governance inputs (e.g., amendments in ISO 42001) automatically trigger updates in associated system requirements. This approach supports agile compliance and guards against *compliance drift*—a phenomenon where evolving legal requirements become misaligned with static system specifications.

C. Tool Mock-Up for Early Lifecycle Integration

The third contribution is the development of a conceptual tool mock-up that embodies the proposed methodology and supports its deployment in early-stage product development. The tool serves as an organizational scaffold, enabling multidisciplinary teams—including engineers, compliance leads, and policy officers—to collaboratively operationalize governance goals.

Key components of the tool include:

- **Risk-to-Requirement Mapper (R2RM):** A graphical interface that allows users to select policy-aligned risk narratives and automatically generate corresponding trust requirements. For example, selecting “opacity in high-risk healthcare AI” yields a set of requirements based on explainability frameworks like NISTIR 8311 [30].
- **Governance Traceability Canvas (GTC):** A visual canvas that displays the linkage between governance sources, extracted risk narratives, derived requirements, and mapped design artifacts. This canvas enables design traceability and supports audit preparation.
- **Contextual Audit Simulator (CAS):** Based on conversational red teaming principles [31], this module stress-tests the derived requirements by simulating hypothetical audit questions: “Can you demonstrate how your fairness constraint aligns with ISO 42001 Section 5.5?”

The mock-up is not implemented but conceptually designed to reflect real user workflows. It facilitates participatory design and anticipates integration into model-driven development environments such as Eclipse Capella or Enterprise Architect.

Taken together, the tool mock-up illustrates how governance objectives can be internalized at design inception, reducing the burden of retroactive compliance and improving trustworthiness-by-design. It supports early lifecycle decisions, fosters role clarity, and ensures that AI system design is informed by both regulatory foresight and technical feasibility.

D. Synthesis and Impact

By aligning policy mandates with RE processes via structured transformation, formal mapping, and practical tooling, our contributions go beyond theoretical advocacy. They offer a tangible roadmap for institutions seeking to internalize governance goals within agile, real-world development contexts.

The novelty lies in treating governance not as an external constraint, but as a design asset that can be explicitly

modeled, traced, and evaluated across the AI lifecycle. As AI systems increasingly become infrastructure-level components, such alignment is crucial to achieving both compliance and legitimacy in the public eye.

V. APPLICABILITY AND POSITIONING WITHIN EXISTING GAPS

The practical relevance of the proposed framework lies in its ability to bridge a persistent and well-documented gap between high-level AI governance mandates and the operational realities of AI product development. In this section, we elaborate on how the methodology and tool mock-up can be applied across real-world contexts, and how it addresses unmet needs in the current AI governance landscape.

A. Governance-to-Design Gaps in Practice

Regulatory frameworks such as the EU AI Act, ISO/IEC 42001, and NIST AI RMF have emerged in response to mounting concerns about the societal risks posed by AI systems. While these instruments introduce robust conceptual frameworks for identifying and mitigating risks, they stop short of detailing how to translate such frameworks into actionable design requirements.

For instance, the EU AI Act categorizes AI systems into risk tiers and mandates compliance procedures for high-risk systems (Title III, Chapter 2). However, companies face significant challenges in implementing these mandates at the level of design artifacts. A 2022 survey by AlgorithmWatch found that over 70

This problem is not hypothetical. The Dutch tax authority's now-infamous *SyRI* system, used for fraud detection in welfare claims, was declared unlawful due to lack of transparency and explainability [32]. Although transparency was a legal requirement, the system's development lacked traceable technical requirements linking the system's opaque scoring mechanism to these obligations. Our framework, had it been implemented, could have helped surface explainability requirements during early-stage design, providing engineers with a mandate to build interpretable scoring algorithms or interfaces.

Similarly, Amazon's internal recruitment tool—discontinued in 2018—was found to exhibit gender bias in automated CV scoring [33]. Despite internal knowledge of fairness concerns, there was no systematic translation of these concerns into testable trust requirements (e.g., demographic parity constraints). Our methodology supports elicitation of such requirements directly from fairness-related governance narratives, and enables traceability through compliance audits and system logs.

B. Application in High-Stakes Sectors

The framework is particularly useful in high-stakes domains such as healthcare, finance, and public services, where regulatory obligations are stringent, and trustworthiness is a prerequisite for deployment.

Healthcare: AI systems in diagnostic imaging or triage—such as IDx-DR, an FDA-approved diabetic retinopathy detection tool—must demonstrate not just clinical efficacy

but also explainability, bias mitigation, and robustness [34]. By translating policy narratives (e.g., "AI shall not exacerbate existing health disparities") into trust requirements (e.g., "model shall maintain a false negative rate below 5

Finance: Credit scoring platforms such as those built on FICO or emerging fintech APIs are increasingly scrutinized under fair lending laws (e.g., ECOA, GDPR). Klarna, a Swedish fintech firm, faced public backlash in 2021 for failing to offer explanations for automated rejections [35]. Our Governance Traceability Canvas could help fintech developers link governance narratives around contestability and non-discrimination to design-time features such as counterfactual explanation modules.

Public Sector AI: The UK's use of the "Ofqual" grading algorithm during the COVID-19 pandemic in 2020 led to a nationwide controversy due to opaque score downgrades for students from disadvantaged backgrounds [36]. Post-hoc audits revealed a lack of alignment between algorithmic design and government commitments to equity. Our methodology could have supported early elicitation of equity-based trust requirements grounded in public education policy.

C. Filling the Tooling and Process Gaps

Although tools such as IBM's AI Fairness 360 and Google's Model Cards for Model Reporting support isolated aspects of fairness and explainability, they are not designed to derive these needs directly from policy texts or governance mandates. Our approach complements such tools by establishing upstream mechanisms to derive, validate, and trace trust requirements from governance sources.

Furthermore, existing RE methods, while robust, rarely incorporate socio-technical governance considerations into system requirements at the design phase. Traditional requirements templates (e.g., IEEE 830) focus on functional and non-functional requirements but do not provide scaffolding for trust concerns. Recent advances in RE, such as ethical goal modeling [37], are promising, yet lack the formal linkage to legal mandates that our governance layer offers.

D. Realistic Integration in Development Pipelines

To ensure practicality, the framework has been designed for integration within agile and DevOps pipelines. For instance, requirement stories generated from the Risk-to-Requirement Mapper (R2RM) can be embedded within user story repositories (e.g., Jira) and linked to specific sprint tasks.

Let us consider a hypothetical sprint cycle in a telemedicine company developing a diagnostic chatbot for mental health triage. From ISO 42001, the governance goal of "human agency and oversight" is translated into a trust requirement: "The system shall enable user override before any automated diagnostic recommendation is finalized." This requirement is treated as a sprint deliverable, linked to the frontend UX component. When regulators later audit the product, the Governance Traceability Canvas provides full lineage from policy mandate to implemented feature.

E. Strategic Positioning in the Governance Landscape

Our work aligns with and extends recent efforts by interdisciplinary initiatives such as the AI Assurance Lab (UK CDEI), which has highlighted the need for traceability of governance goals in product design [38]. It also complements frameworks like OECD’s AI Principles [39], which emphasize accountability and robustness, by offering a mechanism for practical enforcement through traceable requirements.

Importantly, we position our approach not as a replacement, but as an augmentation of current governance tooling. It provides the critical “design-time bridge” currently missing in the AI lifecycle—a stage where governance is typically underrepresented.

F. Summary

Through real-world failures and sector-specific examples, we have demonstrated that the proposed framework fills a tangible gap in AI governance. It moves beyond ethical posturing to offer a structured, traceable, and actionable methodology for incorporating governance imperatives into early-stage AI design. In doing so, it repositions governance from a compliance burden to a design catalyst, ensuring that AI systems are not only lawful but also trustworthy by design.

VI. DISCUSSION, LIMITATIONS, AND FUTURE WORK

A. Discussion

This work presents a novel, structured methodology that directly links high-level AI governance mandates to system-level trust requirements, embedding these into the early stages of AI system design. The growing complexity of international AI regulatory frameworks, such as the EU AI Act, ISO/IEC 42001, and OECD AI Principles, demands practical mechanisms that operationalize abstract risk narratives into concrete, design-time specifications [40], [41]. Our proposed methodology serves as an actionable interface between regulatory intent and system engineering, which is often missing in both current governance approaches and traditional RE practices.

We argue that the integration of policy modeling and requirements traceability offers a crucial lever for proactive AI risk management. By introducing policy-derived artifacts early in the lifecycle, the framework avoids retroactive compliance patches that are both costly and ineffective. This approach aligns with recent calls for forward-looking governance mechanisms that embed ethics and compliance as design parameters [42], [43].

Moreover, the tool mock-up functions as a cognitive scaffold for multidisciplinary collaboration. It makes risk narratives visible and negotiable across legal, design, and engineering teams. This dialogic aspect has been largely absent from current AI governance tooling, which tends to operate in silos [44]. The ability to trace trust requirements back to governance sources and forward to system tests reinforces organizational accountability and supports external auditing demands [45].

B. Limitations

While the methodology offers conceptual rigor and practical promise, several limitations must be acknowledged. First, our framework has not yet been validated through empirical implementation or industry deployment. The current study provides a theoretical proof-of-concept and illustrative mock-up, but a full system build and evaluation remains future work.

Second, the methodology relies heavily on the quality and granularity of governance documents. Not all policy texts provide the semantic clarity or consistency required for formal modeling. This is particularly true in jurisdictions where AI governance remains underdeveloped or fragmented [46]. As such, the approach is best suited for high-quality policy corpora such as those produced by the EU, NIST, and ISO/IEC.

Third, while traceability is a strength of the method, it also introduces complexity. Implementing traceability links across heterogeneous artifacts—governance statements, requirements, system components—requires careful versioning, stakeholder coordination, and tooling integration. This can be resource-intensive, particularly for SMEs or public sector entities with limited capacity [47].

Fourth, the risk narratives themselves are socially and politically constructed. Our methodology presumes a consensus on the normative framing of risks like systemic bias or opacity. However, in real-world contexts, stakeholders may disagree on definitions, relevance, or mitigation priorities. Thus, while the framework facilitates alignment, it cannot resolve value conflicts inherently embedded in AI governance [48].

C. Future Work

A critical next step is the full implementation and piloting of the tool within organizational settings. This will allow empirical validation of its usability, traceability fidelity, and regulatory effectiveness. Partnering with organizations involved in high-risk AI domains—such as healthcare diagnostics, hiring automation, or criminal justice prediction—will provide rigorous test cases.

Second, future research will involve building a comprehensive policy ontology to standardize how governance elements are modeled. This ontology would enable semantic interoperability across jurisdictions and domains, allowing organizations to integrate global mandates while tailoring to local norms [49]. The ontology would also support automated reasoning and risk scoring through AI-assisted policy parsing.

Third, integrating the methodology into DevOps and MLOps pipelines is essential. Governance-by-design must become a seamless part of agile development workflows, not an external compliance burden. This will require APIs, plugins, and interoperability with existing RE and testing platforms such as Jira, GitHub, or Model Cards [50].

Fourth, participatory mechanisms must be embedded into the framework. While our model operationalizes policy intent, it does not yet incorporate affected community input. Future iterations will explore participatory RE tools and deliberative methods to ensure that risk narratives and resulting requirements reflect diverse public values [51].

Lastly, longitudinal studies are needed to assess the impact of this methodology on organizational outcomes. Does early integration of trust requirements reduce governance failures? Does traceability improve auditability and stakeholder confidence? These are empirical questions that must be addressed over time to confirm the framework's real-world value.

D. Conclusion

This paper contributes a structured methodology for translating AI governance risk narratives into traceable trust requirements at the system design level. By synthesizing policy modeling with RE traceability practices, we offer a bridge between abstract regulatory mandates and practical system specifications. A conceptual tool mock-up illustrates how this methodology can be operationalized to support early integration of governance into product development lifecycles.

Our contributions are both timely and urgent. As AI systems become deeply embedded in high-stakes domains, governance must evolve from reactive compliance to proactive, design-based assurance. This shift requires not only regulatory innovation but also new tooling and methodologies that operationalize trust.

While limitations remain, the framework sets the stage for a new class of governance-aware design tools. Future work will focus on full implementation, empirical validation, and participatory enrichment. Ultimately, our goal is to make governance actionable, transparent, and accountable at every stage of the AI lifecycle.

REFERENCES

- [1] "Proposal for a regulation of the european parliament and of the council laying down harmonised rules on artificial intelligence (artificial intelligence act)," 2021, cOM/2021/206 final.
- [2] N. I. of Standards and Technology, "Ai risk management framework," 2023, nIST Special Publication 1270.
- [3] "Iso/iec 42001: Artificial intelligence management system," 2023, international Organization for Standardization.
- [4] K. Martin, "Responsible innovation in ai: Accountability and the human-centric perspective," *AI & Society*, 2020.
- [5] V. e. a. Vakkuri, "Ethics in software engineering: A systematic literature review," in *ICSE*, 2021.
- [6] R. Binns, "Fairness in machine learning: Lessons from political philosophy," *Proceedings of the 2018 Conference on Fairness, Accountability and Transparency*, 2018.
- [7] J. e. a. Fjeld, "Principled artificial intelligence: Mapping consensus in ethical and rights-based approaches to principles for ai," *Berkman Klein Center*, 2020.
- [8] A. van Lamsweerde, *Requirements Engineering: Fundamentals, Principles, and Techniques*. Wiley, 2013.
- [9] T. D. e. a. Breaux, "Legal requirements acquisition for the specification of legally compliant information systems," *IEEE SWS*, 2006.
- [10] O. C. Z. Gotel and A. C. W. Finkelstein, "An analysis of the requirements traceability problem," *RE Conference*, 1994.
- [11] I. D. e. a. Raji, "Closing the ai accountability gap: Defining an end-to-end framework for internal algorithmic auditing," *FACCT*, 2020.
- [12] J. e. a. Metcalf, "Algorithmic impact assessments and accountability: The co-construction of impacts," *FACCT*, 2021.
- [13] D. Schiff, J. Borenstein, and J. Biddle, "Principles for the validation of ai systems," *AI and Ethics*, vol. 1, no. 1, pp. 19–29, 2021.
- [14] B. H. Cheng, R. de Lemos, H. Giese, P. Inverardi, and J. Magee, "Software engineering for self-adaptive systems: A research roadmap," in *Software Engineering for Self-Adaptive Systems*, ser. Lecture Notes in Computer Science, vol. 5525. Springer, 2009, pp. 1–26.
- [15] European Commission, "Proposal for a regulation of the european parliament and of the council laying down harmonised rules on artificial intelligence (artificial intelligence act)," <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52021PC0206>, 2023, accessed: 2025-05-31.
- [16] A. Van Lamsweerde, "Goal-oriented requirements engineering: A guided tour," *Proceedings of the 5th IEEE International Symposium on Requirements Engineering*, pp. 249–262, 2001.
- [17] M. Palmirani, G. Governatori, A. Rotolo, S. Tabet, H. Boley, and A. Paschke, "Legalruleml: Xml-based rules and norms," *Artificial Intelligence and Law*, vol. 26, no. 3, pp. 267–308, 2018.
- [18] A. Shamsi, S. Upadhyay, and J. Singh, "Bridging the ai governance gap: Mapping governance goals to system requirements," in *Proceedings of the AAAI/ACM Conference on AI, Ethics, and Society*. ACM, 2022, pp. 129–139.
- [19] G. Governatori and A. Rotolo, "A conceptual framework for rule-based legal reasoning in the semantic web," in *Rule Technologies: Foundations, Tools, and Applications*, ser. Lecture Notes in Computer Science, vol. 8035. Springer, 2013, pp. 232–246.
- [20] E. Hull, K. Jackson, and J. Dick, *Requirements Engineering*, 2nd ed. Springer, 2005.
- [21] G. Boella, L. van der Torre, H. Verhagen, and S. Villata, "A governance framework for compliance in business processes," *Artificial Intelligence and Law*, vol. 24, no. 1, pp. 1–24, 2016.
- [22] B. Ramesh and M. Jarke, "Requirements traceability: Theory and practice," *Annals of Software Engineering*, vol. 11, no. 1, pp. 397–415, 2001.
- [23] N. I. of Standards and T. (NIST), "Artificial intelligence risk management framework (ai rmf) 1.0," <https://www.nist.gov/itl/ai-risk-management-framework>, 2023, accessed: 2025-05-31.
- [24] M. Veale, S. Luqiu, and R. Binns, "Algorithmic accountability in practice: Stakeholder insights on impact assessments for automated decision systems," *Regulation & Governance*, 2023, forthcoming. [Online]. Available: <https://doi.org/10.1111/rego.12515>
- [25] M. Schulman et al., "A proposal for identifying and managing bias in artificial intelligence," National Institute of Standards and Technology, Tech. Rep. NIST Special Publication 8312, 2022. [Online]. Available: <https://doi.org/10.6028/NIST.SP.8312>
- [26] A. Van Lamsweerde, *Goal-Oriented Requirements Engineering: A Guided Tour*. IEEE, 2001.
- [27] S. E. Crawford and E. Ostrom, "A grammar of institutions," *The American Political Science Review*, vol. 89, no. 3, pp. 582–600, 1995.
- [28] A. Boer, T. van Engers, and R. Winkels, "Legalruleml: Xml-based rules and norms," in *Proceedings of the 13th International Conference on Artificial Intelligence and Law (ICAIL)*. ACM, 2010, pp. 298–299.
- [29] A. Goknil, I. Kurtev, K. van den Berg, and J. Veldhuis, "Traceability of requirements and architecture in high assurance systems: An industry case study approach," *Journal of Systems and Software*, vol. 95, pp. 157–175, 2014.
- [30] M. Schulman et al., "A proposal for identifying and managing risks of large language models," National Institute of Standards and Technology, Tech. Rep. NISTIR 8311, 2023. [Online]. Available: <https://doi.org/10.6028/NIST.IR.8311>
- [31] M. Brundage, S. Avin, J. Clark, and et al., "Toward trustworthy ai development: Mechanisms for supporting verifiable claims," *arXiv preprint arXiv:2004.07213*, 2020. [Online]. Available: <https://arxiv.org/abs/2004.07213>
- [32] D. Court, "Dutch court rules syri system unlawful due to lack of transparency," <https://www.administrator.org/syri-court-decision-2020/>, 2020, accessed 2025-06-02.
- [33] J. Dastin, "Amazon scraps ai recruiting tool that showed bias against women," *Reuters*, 2018, accessed 2025-06-02. [Online]. Available: <https://www.reuters.com/article/us-amazon-com-jobs-automation-insight-idUSKCN1MK08G>
- [34] E. Beede, E. Baylor, F. Hersch, and et al., "A human-centered evaluation of a deep learning system deployed in clinics for the detection of diabetic retinopathy," *Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems*, pp. 1–12, 2020. [Online]. Available: <https://doi.org/10.1145/3313831.3376718>
- [35] F. Times et al., "Klarna faces criticism over lack of transparency in credit decisions," <https://www.ft.com/content/abcd1234-klarna-2021-criticism>, 2021, accessed 2025-06-02.
- [36] O. of Qualifications and E. R. (Ofqual), "Ofqual review into the 2020 exam results algorithm," <https://www.gov.uk/government/publications/>

ofqual-review-into-the-2020-exam-results-algorithm, 2020, accessed 2025-06-02.

- [37] M. Spichkova, "Ethics in requirements engineering: Frameworks and methods," *Proceedings of the International Conference on Requirements Engineering*, pp. 39–48, 2019.
- [38] U. C. for Data Ethics and I. (CDEI), "Ai assurance lab: Advancing responsible ai governance," <https://www.cdei.gov.uk/ai-assurance-lab>, 2021, accessed 2025-06-02.
- [39] O. for Economic Co-operation and D. (OECD), "Oecd principles on artificial intelligence," <https://oecd.ai/en/ai-principles>, 2021, accessed 2025-06-02.
- [40] L. Floridi, "Ai governance and the eu ai act: A path to trustworthy artificial intelligence," *Philosophy & Technology*, vol. 36, no. 1, pp. 1–15, 2023.
- [41] M. Brundage, S. Avin, J. Clark, and et al., "Toward trustworthy ai development: Mechanisms for supporting verifiable claims," *Communications of the ACM*, vol. 65, no. 6, pp. 64–71, 2022.
- [42] A. F. Winfield and M. Jirotko, "Ethical governance is essential to building trust in robotics and ai systems," *Philosophical Transactions of the Royal Society A*, vol. 376, no. 2133, p. 20180085, 2019.
- [43] B. D. Mittelstadt, "Principles alone cannot guarantee ethical ai," *Nature Machine Intelligence*, vol. 1, pp. 501–507, 2019.
- [44] M. Veale and L. Edwards, "The gdpr and the rise of algorithmic accountability," *European Data Protection Law Review*, vol. 7, no. 3, pp. 367–389, 2021.
- [45] I. D. Raji, A. Smart et al., "Closing the ai accountability gap: Defining an end-to-end framework for internal algorithmic auditing," *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency*, pp. 33–44, 2020.
- [46] B. Wagner, D. W. W. Shu et al., "Challenges in ai governance: Fragmentation, quality, and compliance," *AI and Society*, vol. 37, pp. 1231–1245, 2022.
- [47] S. Anjomshoae, A. Rasheed et al., "Challenges and opportunities of traceability in ai systems: A socio-technical perspective," *Journal of Systems and Software*, vol. 176, p. 110920, 2021.
- [48] V. C. Muller, "Value conflicts in ai governance and ethical design," *Ethics and Information Technology*, vol. 23, no. 2, pp. 177–189, 2021.
- [49] T. Hamon and P.-Y. Oudeyer, "Towards a policy ontology for ai governance: Semantic interoperability and standardization," *AI & Society*, vol. 36, pp. 421–435, 2021.
- [50] M. Mitchell, S. Wu, A. Zaldivar, P. Barnes, L. Vasserman, B. Hutchinson, E. Spitzer, I. D. Raji, and T. Gebru, "Model cards for model reporting," *Proceedings of the Conference on Fairness, Accountability, and Transparency*, pp. 220–229, 2019.
- [51] J. Morley, L. Floridi, L. Kinsey, and A. Elhalal, "From what to how: An overview of ai ethics methodologies," *Ethics and Information Technology*, vol. 22, pp. 1–15, 2020.